Kerberos

Protocolo de autentificación

¿Qué es Kerberos?

- **Protocolo de autentificación**, no de autorización: no determina a qué recursos o servicios puede acceder o no dicho usuario.
- Kerberos es ampliamente utilizado en **Active Directory**. En esta plataforma Kerberos da información de los privilegios de cada usuario autenticado, pero queda a cargo de los servicios el verificar que dichos privilegios son suficientes para acceder a sus recursos.

- Utiliza UDP o TCP como protocolos de transporte, que transmiten la información en claro, por lo cual es necesario que se encargue él mismo de proporcionar la capa de cifrado.
- El protocolo Kerberos utiliza los puertos UDP/88 y TCP/88, que se deben encontrar a la escucha en el KDC.

Agentes en Kerberos

En Kerberos intervienen varios servicios encargados de realizar la autenticación del usuario. Entre estos se encuentran los siguientes:

- El **cliente o usuario** que quiere acceder al servicio.
- El **AP** (Application Server) donde se expone el servicio al que el usuario quiere acceder.
- El **KDC** (Key Distribution Center), el servicio de Kerberos encargado de distribuir los tickets a los clientes, instalado en el DC (Controlador de dominio). Cuenta con el **AS** (Authentication Service), que se encarga de expedir los TGTs.

Claves de cifrado en Kerberos

Varias estructuras manejadas por Kerberos, como los tickets, se transmiten cifradas o firmadas. Esto evita que sean manipuladas por terceros. Las claves de cifrado utilizados por Kerberos, en Active Directory, son las siguientes:

- **Clave del KDC o krbtgt**: clave derivada del hash NTLM de la cuenta krbtgt.
- **Clave de usuario**: clave derivada del hash NTLM del propio usuario.
- **Clave de servicio**: clave derivada del hash NTLM del propietario del servicio, que puede ser una cuenta de usuario o del servidor.
- **Clave de sesión**: clave negociada por el cliente y el KDC.
- **Clave de sesión de servicio**: clave negociada para utilizar entre el cliente y el AP.

Tickets y PAC

Kerberos maneja unas estructuras llamadas “Tickets”, que son entregados a los usuarios autenticados para que estos puedan realizar ciertas acciones dentro del dominio de Kerberos. Se distinguen 2 tipos:

- El **TGT** (Ticket Granting Ticket) es el ticket que se presenta ante el KDC para obtener los TGS. Se cifra con la clave del KDC.
- El **TGS** (Ticket Granting Service) es el ticket que se presenta ante un servicio para poder acceder a sus recursos. Se cifra con la clave del servicio correspondiente.

El **PAC** (Privilege Attribute Certificate) es una estructura incluida en la mayoría los tickets. Esta estructura contiene los privilegios del usuario y está firmada con la clave del KDC.

Mensajes

El protocolo Kerberos permite la comunicación de los diferentes agentes a través de diferentes tipos de mensajes. A continuación se enumeran los más interesantes:

KRB_AS_REQ: Utilizado por el usuario para solicitar el TGT al KDC.

KRB_AS_REP: Respuesta del KDC para enviar el TGT al usuario.

KRB_TGS_REQ: Utilizado por el usuario para solicitar el TGS al KDC, utilizando el TGT.

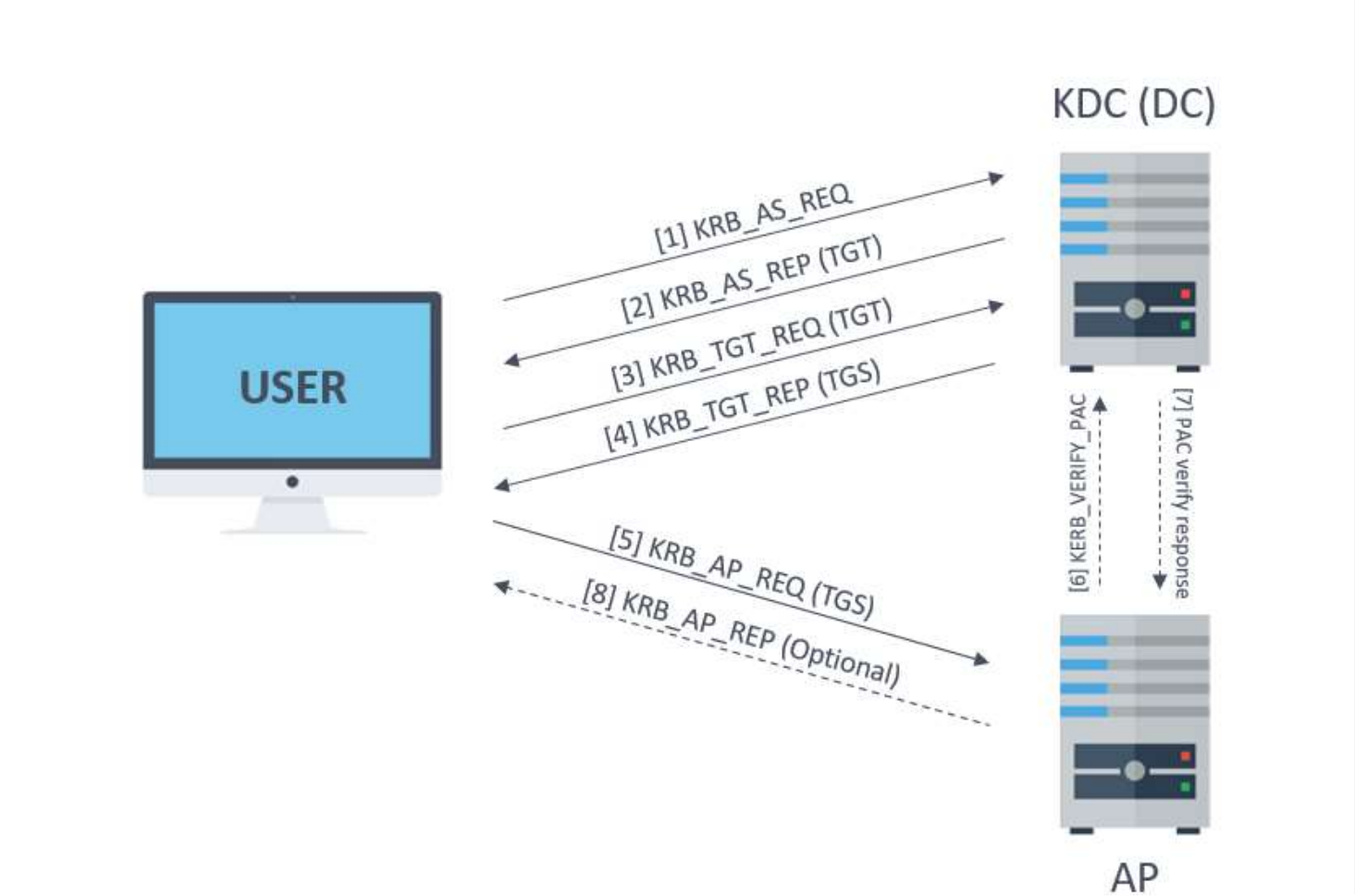
KRB_TGS_REP: Respuesta del KDC para enviar el TGS solicitado al usuario.

KRB_AP_REQ: Utilizado por el usuario para identificarse contra el servicio deseado, utilizando el TGS del propio servicio.

KRB_AP_REP: (Opcional) Utilizado por el servicio para autenticarse frente al usuario.

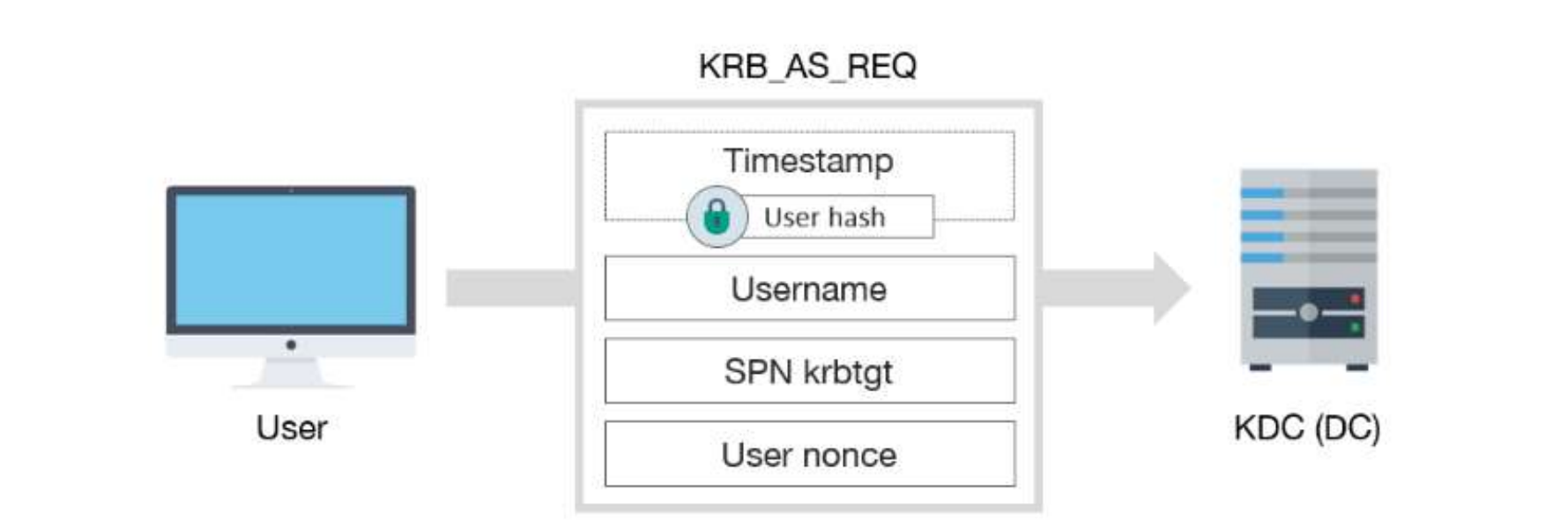
K**RB_ERROR**: Utilizado por los diferentes agentes para notificar situaciones de error.

Mensajes


KDC (DC)
USER
[1] KRB_AS_REQ
[2] KRB_AS_REP (TGT)
[3] KRB_TGT_REQ (TGT)
[4] KRB_TGT_REP (TGS)
[5] KRB_AP_REQ (TGS)
[8] KRB_AP_REP (Optional)
[6] KERB_VERIFY_PAC
[7] PAC verify response
AP

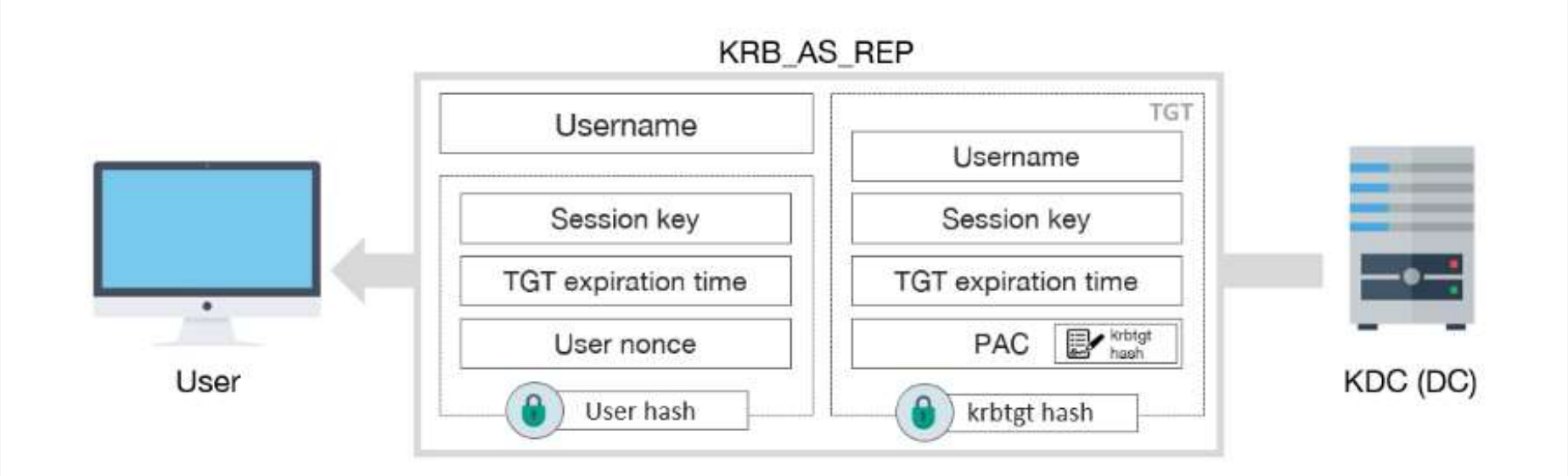
Proceso de autentificación

Lo primero que un usuario debe conseguir es un TGT del KDC, para ello se envía un mensaje *KRB_AS_REQ*:



Proceso de autentificación

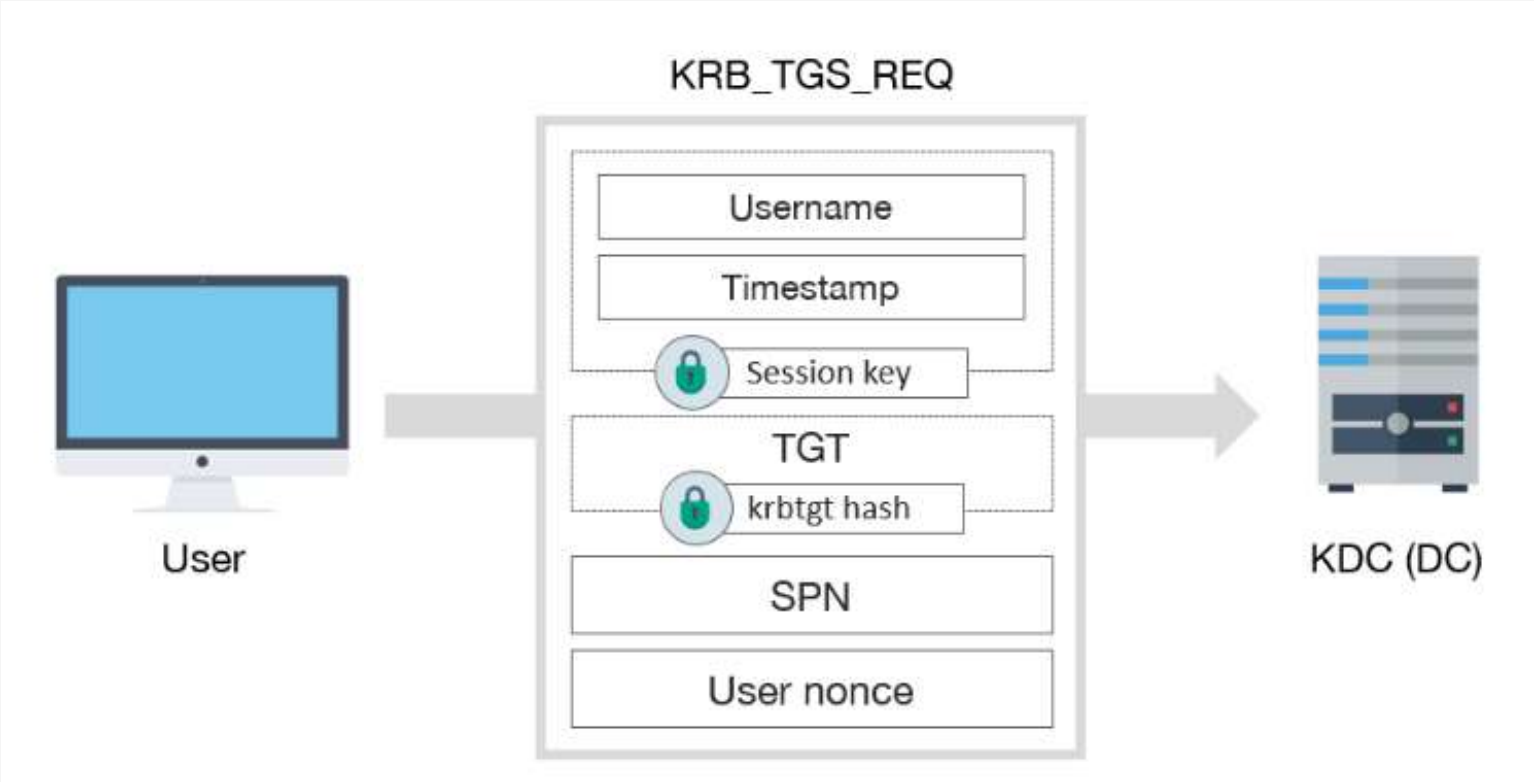
El KDC verifica la identidad del usuario descifrando el timestamp. Si el mensaje recibido es correcto entonces responde con un KRB_AS_REP:



Una vez terminado este proceso el usuario ya posee un TGT que podrá ser usado para solicitar los TGS, y acceder a los servicios del dominio ligados a Kerberos.

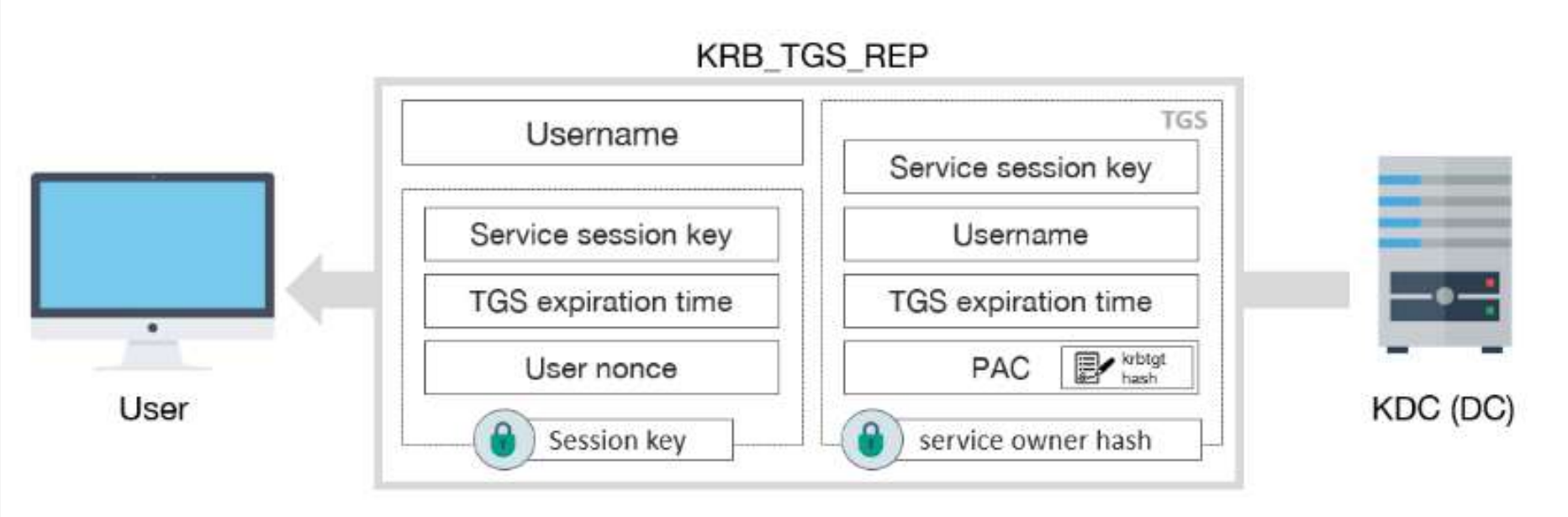
Solicitud de acceso a servicios

Para solicitar un TGS se debe enviar al KDC un mensaje KRB_TGS_REQ



Solicitud de acceso a servicios

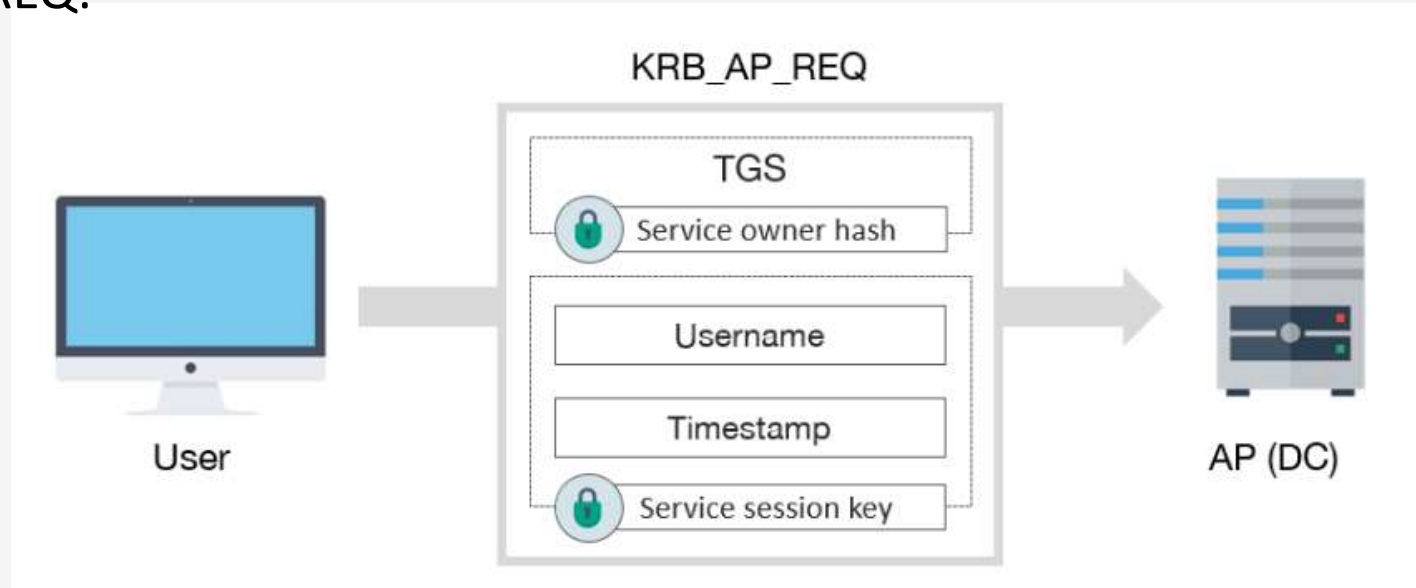
Cuando el KDC recibe este mensaje devuelve un TGS en el mensaje KRB_TGS_REP:



El usuario ya tiene el TGS que le permite acceder al servicio deseado

Acceso a servicios

Para acceder a un servicio usando el TGS, el cliente debe enviar al AP un mensaje KRB_AP_REQ:



Si los permisos del usuario son correctos, este ya puede acceder al servicio.

Si está configurado, el AP verificará contra el KDC el PAC. Y en caso de requerir autenticación mutua, responderá con un mensaje KRB_AP_REP al usuario

Ataques a Kerberos

Overpass The Hash/Pass The Key (PTK)

La definición general del ataque Pass The Hash (PTH) es la de ataque que utiliza el hash del usuario para conseguir suplantar al mismo. Llevado al campo de los tickets Kerberos se denomina Overpass The Hash o Pass The Key.

Si un atacante consigue obtener el hash de un usuario podría suplantar a este frente al KDC, y acceder a los servicios del dominio disponibles para dicho usuario.

Los hashes de usuario se pueden extraer de los ficheros SAM de las estaciones de trabajo, del fichero NTDS.DIT de los DC, o de la memoria del proceso lsass (utilizando la herramienta Mimikatz) donde también es posible obtener las contraseñas en texto claro.

Ataques a Kerberos

Pass The Ticket (PTT)

El Pass The Ticket se trata de obtener un ticket de usuario y utilizarlo para ganar acceso a los recursos para los que el usuario tenga permisos. Sin embargo, además del ticket, es necesario conseguir también la clave de sesión respectiva, para poder usar este en las comunicaciones con el servicio.

Se pueden obtener los tickets mediante un ataque de **Man-In-The-Middle**, ya que estos viajan sobre UDP o TCP. No obstante, mediante este técnica no se consigue acceso a la clave de sesión.

El otro método, ampliamente utilizado, es extraer dichos tickets de la memoria del proceso lsass, donde también se pueden encontrar las claves de sesión. Este procedimiento se puede realizar con la herramienta Mimikatz.

Es preferible obtener un TGT, debido a que el TGS cuenta con la limitación de que solamente se puede utilizar contra un servicio, pero ambos pueden ser utilizados para este tipo de ataque.

Se debe tener en cuenta que el tiempo por defecto de vida de los tickets es de 10 horas, tras lo cual no podrán ser utilizados.

Ataques a Kerberos

Golden Ticket y Silver Ticket

El objetivo del ataque del Golden Ticket es construir un TGT, para lo cual se necesita la clave del krbtgt. Por tanto si se obtiene el hash NTLM de la cuenta krbtgt, es posible construir un TGT. Dicho TGT puede contar con la caducidad y permisos que se desee, consiguiendo incluso privilegios de administrador de dominio.

El ticket continuará siendo válido aunque el usuario incluido cambie su contraseña. El TGT solo podrá ser invalidado si expira o cambia la contraseña de la cuenta krbtgt.

El Silver Ticket es similar, pero esta vez se construye un TGS y lo que se requiere es la clave del servicio al que se quiere acceder. Esta clave se deriva del hash NTLM de la cuenta propietaria del servicio. Esta técnica no funcionará si el servicio verifica el PAC, ya que al no conocer la clave de krbtgt, no es posible firmarlo correctamente.

Ataques a Kerberos

Kerberoasting

El Kerberoasting trata de usar los TGS para realizar cracking de las contraseñas de los usuarios offline.

Como se ha visto anteriormente, los TGS vienen cifrados con la clave del servicio, que se deriva del hash NTLM de la cuenta propietaria del servicio. Normalmente los servicios son propiedad de las cuentas de ordenador en que se ejecutan. No obstante, estas contraseñas son demasiado complejas como para ser crackeadas. Esto también aplica a la cuenta krbtgt, haciendo que tampoco se pueda crackear el TGT.

Pese a todo, en algunas ocasiones los propietarios de los servicios son cuentas de usuario normal. En estos casos es más factible crackear las contraseñas. Además, este tipo de cuentas suelen ser privilegiadas. Se debe tener en cuenta que con cualquier usuario de dominio es posible obtener un TGS para cualquier servicio, debido a que Kerberos no se encarga de la autorización.

gracias a

TARLOGIC
CYBERSECURITY EXPERTS
INICIO
CIBERSEGURIDAD
BLACKARROW
CIBERINTELIGENCIA
BLOG
CONTACTO
< Volver al blog
Kerberos (I): ¿Cómo funciona Kerberos? – Teoría
20 - MAR - 2019 - ELOY PÉREZ

LDAP

Bases de datos de usuarios

¿Qué es LDAP?

- **Protocolo Ligero de Acceso a Directorio** (Lightweight Directory Access Protocol) hace referencia a un protocolo a nivel de aplicación que permite el acceso a un servicio de directorio ordenado y distribuido para buscar diversa información en un entorno de red.

- Un **directorio** remoto es un conjunto de objetos que están organizados de forma lógica y jerárquica, tales como nombre, claves, direcciones, etc.

- Tienden a usar nombres de Sistema de Nombres de Dominio (DNS) para estructurar los niveles más altos de la jerarquía. Conforme se desciende en el directorio pueden aparecer entradas que representan personas, unidades organizacionales, impresoras, documentos, grupos de personas o cualquier cosa que representa una entrada dada en el árbol (o múltiples entradas).

¿Qué es LDAP?

- Habitualmente, almacena la información de **autenticación** (usuario y contraseña) y es utilizado para autenticarse aunque es posible almacenar otra información (datos de contacto del usuario, ubicación de diversos recursos de la red, permisos, certificados, etc)

- Un servidor LDAP está comunicado con otros, de forma que componen una base de datos de información descentralizada.

- La versión actual se denomina **LDAPv3** y se encuentra definida en una hoja de documentación RFC 4511 accesible de forma pública.

Protocolo

- Un cliente inicia una sesión de LDAP conectándose a un servidor LDAP, preestablecido en el puerto **TCP 389.** El cliente luego envía una petición de operación al servidor, y el servidor envía respuestas.
- El cliente puede requerir algunas de las siguientes operaciones:

  Start TLS: usar la extensión Transport Layer Security (TLS) LDAPv3 para una conexión segura

  Bind: autenticarse y especificar una versión del protocolo LDAP

  Search: buscar y obtener entradas de directorio

  Compare: probar si una entrada nombrada contiene un valor de atributo dado

  Add: Añadir una nueva entrada

  Delete: Borrar una entrada

  Modify: Modificar una entrada

  Modify Distinguished Name (DN): Modificar o renombrar una entrada

Estructura de directorio

- Un directorio es un árbol de entradas de directorio.
- Una entrada consta de un conjunto de atributos.
- Un atributo tiene un nombre (un tipo de atributo o descripción de atributo) y uno o más valores. Los atributos son definidos en un esquema.
- Cada entrada tiene un identificador único llamado **Nombre distinguido** (Distinguished Name, DN), formado por:
  - Algunos atributos de entrada
  - seguidos del nombre distinguido del padre

Entradas

- LDAP por sí mismo es un protocolo binario. La información de cada entrada se representa en formato LDIF (LDAP Data Interchange Format).

```
dn: cn=John Doe,dc=example,dc=com
cn: John Doe
givenName: John
sn: Doe
telephoneNumber: +1 888 555 6789
telephoneNumber: +1 888 555 1232
mail: john@example.com
manager: cn=Barbara Doe,dc=example,dc=com
objectClass: inetOrgPerson
objectClass: organizationalPerson
objectClass: person
objectClass: top
```

"dn" es el nombre de la entrada (ojo, no es un atributo)

"cn=John Doe" es el nombre distinguido relativo

"dc=example,dc=com" es el nombre distinguido de la entrada del padre

dc = componente de dominio
cn = nombre común
sn = (surname) apellidos

Implementaciones

En la actualidad existen diversas herramientas que utilizan este protocolo para la comunicación cliente servidor de un servicio de directorio.

- **OpenLDAP**: es la implementación libre del protocolo LDAP. Tiene su propia licencia y es compatible con otros servidores que utilicen el mismo protocolo. Es utilizado por distintas distribuciones Linux y BSD.
- **MS Active Directory**: es un almacén de datos de directorio con licencia Microsoft e implementado en sus sistemas operativos server desde Windows 2000. Realmente bajo la estructura de Active Directory se encuentra un esquema LDAPv3, por lo que también es compatible con otros sistemas que implemente este protocolo en sus directorios.
- **Red Hat Directory Server**: es un servidor que también se basa en LDAP similar a Active Directory, pero mediante una herramienta de código abierto. Dentro de este directorio podremos almacenar objetos como usuarios claves, grupos, políticas de permisos, etc.

Implementaciones

- **Apache Directory Server**: otra de las grandes implementaciones que utilizan LDAP es el directorio con licencia de Apache Software. Además, implementa otros protocolos como Kerberos y NTP y cuenta con una interfaz de vistas propias de las bases de datos relacionales.
- **Novell Directory Services**: este es el servidor de directorio propio de Novell para gestionar el acceso a un almacén de recursos en uno o varios servidores conectados en red. Se compone de una estructura de base de datos jerárquica orientada a objetos en la que se almacenan todos los objetivos típicos de los directorios.
- **Open DS**: terminamos esta lista con el directorio basado en java de SUN Microsystems, que posteriormente se liberaría para todos los usuarios. Por supuesto, está desarrollado en JAVA el necesitaremos el paquete Java Runtime Environmet para que éste funcione.

FreeIPA Identidad-Políticas-Auditoría Libre

Suite de software de código libre (2008) patrocinado por RedHat, cuyo objetivo es proporcionar una interfaz segura de administración de identidades y servicios orientado a entornos de red basados en GNU/Linux.

- Basado en el proyecto 389 Directory Server de RedHat
- Integra OpenLDAP para el servicio de directorio
- MIT Kerberos 5 para la autentificación y sesiones
- Apache HTTP Server y Apache Tomcat para la interfaz de administración
- web service, Python para la instalación y configuración del sistema
- NTP para la sincronización horaria
- Dogtag para la integración de certificados CA y RA
- Plugin personalizado de BIND para gestionar los DNS
- Samba para la integración con MS Active Directory

El mayor acierto del proyecto es proveer una interfaz web de administración de identidades y la administración de los servicios integrados.